



File No.: EXP202312988

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: Mr. A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on July 25, 2023. The complaint is directed against COLEGIO VIRGEN DE EUROPA, S.L. with NIF B28773794 (hereinafter, the SCHOOL). The reasons for the complaint are as follows:

The complainant states that the SCHOOL created an email account ***EMAIL.1 for his daughter, a minor under 14 years of age, without obtaining the consent of the guardians for the creation of said email account or for working with a Classroom profile. On November 20, 2022, he became aware that someone had impersonated his daughter and was posing as her by sending emails from the account ***EMAIL.1 to different people, as well as accessing the content of her profile in Classroom and writing in her name.

These facts were communicated to the SCHOOL.

The complainant asserts that the SCHOOL has not notified the security breach nor has it given any importance to the matter.

He also highlights that they requested the Classroom event logs with the IP address and were not provided with them. Furthermore, he states that the security measures were not optimal; as the password for the email account for all children was the initials of the minor plus the mother's date of birth, without enforcing a change, allowing for identity theft with little effort.

The complainant points out that the privacy policy of the respondent does not contain the contact details of the DPO. However, if the DPO is searched on the website www.aepd.es, the contact for the DPO is ***EMAIL.2, but this email does not exist.

Along with the complaint, the email sent on November 20, 2022, to report the incident in Classroom and a printout of the email sent to the DPO's email address, which could not be delivered, are provided.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the complaint was forwarded to the SCHOOL for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on September 29, 2023, as stated in the certificate in the file.

On October 30, 2023, a document was received in this Agency, registered on October 27, responding, stating, verbatim, that:

“3. Report on the causes that led to the incident that originated the complaint.

Regarding the causes that led to the incident, the origin is due to the report of a possible incident by the guardian of the minors, regarding a possible access to the platform enabled for the management of teaching.

4. Report on the measures adopted to prevent similar incidents, date of implementation, and controls carried out to verify their effectiveness.

In relation to the report concerning the measures adopted to prevent similar incidents, dates of implementation, and controls carried out, it consists of the following measures:

From the management, we are aware that, in the processes of data management, in which the personnel of the School is involved, training and awareness of the same is essential for the proper processing of requests, inquiries, or incidents that may arise.

Likewise, in compliance with the principle of transparency, the School periodically reviews any type of clause, form, or communication made, as established in Articles 13 and 14 of the European Data Protection Regulation.

Based on the above, the Data Controller has defined the following verifications as an integral part of

the existing processes:

- Review of the clauses in compliance with the duty of information, as well as the consent of the data subject or representative, for each of the purposes of data processing.
- Likewise, the procedure for consulting the privacy policy will be reinforced.
- Furthermore, as we have previously indicated, being aware that the management of these processes depends on the awareness and knowledge of the user in charge within the entity, actions were taken during the fiscal year

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeapd.gob.es

3/27

of 2022, for the development of a training program, to achieve this culture of data protection.

In this regard, in this initial organization, the training was aimed at the workers responsible for managing communications, with the objective of training and raising awareness among all, with the content of the training program being:

UNIT 1. THE EUROPEAN DATA PROTECTION REGULATION (EU) 2016/679

UNIT 2. FUNDAMENTALS FOR DATA PROCESSING.

UNIT 3. DATA CONTROLLER AND DATA PROCESSOR.

UNIT 4. RIGHTS OF THE DATA SUBJECTS.

UNIT 5. ACTIVE RESPONSIBILITY MEASURES I

UNIT 6. ACTIVE RESPONSIBILITY MEASURES II

As we anticipated earlier, the management processes regarding data protection are under constant review and assessment, as we, from the entity, are aware of the constant exposure and need to comply with the guarantees established by current regulations.”

THIRD: On October 25, 2023, in accordance with Article 65 of the LOPDGDD, the complaint filed by the claimant was admitted for processing.

FOURTH: According to the report collected from the AXESOR tool, the entity COLEGIO VIRGEN DE EUROPA, S.L. is a medium-sized company established in 1982, with a turnover of 11,181,007 euros in 2023.

FIFTH: On April 23, 2024, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the respondent, in accordance with the provisions of Articles 63 and 64 of the LPACAP, for the alleged infringement of Articles 6.1, 13, and 32 of the GDPR, with the first two being classified under Article 83.5 of the GDPR and the last under Article 83.4 of the GDPR.

SIXTH: Once the aforementioned initiation agreement was notified in accordance with the rules established in the LPACAP, the respondent submitted a written statement of allegations on May 9, 2024, in which, in summary, they stated that:

1. Regarding the first fact mentioned in this sanctioning procedure, the creation of the email address, they mention among other issues:

The situation of creating the email address responded to an educational need, and it was carried out during the exceptional period of COVID-19, due to the need for a rapid adaptation of the existing educational systems at that time.

Therefore, the communication regarding the creation of the email address was carried out through emails with the guardians of the minors, and to which there was no impediment or refusal from the guardian of the minor referred to in the complaint.

However, after this moment of exceptional adaptation, they adapted systems to collect consent, in accordance with the requirements established by the legislator.

2. They mention the security measures and instructions conveyed in the management of this system and that have been implemented, in compliance with the provisions of Articles 24 and 32 of the aforementioned European Data Protection Regulation.

3. Regarding the information provided in compliance with the duty of information, enshrined in Article 13 of the European Data Protection Regulation, they point out the following issues:

They state that the entity has adapted its systems for processing personal data in accordance with the

provisions of the General Data Protection Regulation (EU) 2016/679 and Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights.

The School does not allow the collection of data, as well as the processing of those data that are not strictly necessary for the purpose pursued in each case, providing the procedures implemented by the center.

4. They convey the measures adopted due to the incident that arose at that time.

SEVENTH: On October 18, 2024, a resolution proposal was issued proposing to sanction COLEGIO VIRGEN DE EUROPA, S.L., with NIF B28773794, for an infringement of Article 6.1 of the GDPR and Article 13 of the GDPR classified under Article 83.5 of the GDPR, and for an infringement of Article 32 of the GDPR classified under Article 83.4 of the GDPR, with the following fines:

- For the infringement of Article 6.1 of the GDPR, classified under Article 83.5 of that regulation, an administrative fine of 4,500.00 euros.

- For the infringement of Article 13 of the GDPR, classified under Article 83.5 of that regulation, an administrative fine of 1,000.00 euros.

- For the infringement of Article 32 of the GDPR, classified under Article 83.4 of that regulation, an administrative fine of 4,500.00 euros.

EIGHTH: Once the resolution proposal was notified in accordance with the rules established in the LPACAP, the respondent submitted a written statement of allegations on November 4, 2024, reiterating the statements already made regarding the initiation agreement.

The only new point raised by the respondent is that the control authority has indicated a lack of information regarding the contact related to the figure of the Data Protection Officer, disagreeing with this, as it is identified in the various procedures, data collection forms, clauses, and in the privacy policy on their website.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeae@aepd.gob.es

5/27

From the actions taken in the present procedure and the documentation in the file, the following has been established:

PROVEN FACTS

FIRST: It is proven in the file that the SCHOOL created an email ***EMAIL.1 for a student of the educational center who is under 14 years old.

SECOND: It is established in the file through a declaration from the entity itself that, in the process of creating said email account, the SCHOOL limited itself to communicating the creation of the email addresses by sending emails to the guardians of the minors.

THIRD: It is proven in the file that the email sent to the DPD at the following email address ***EMAIL.2 was returned due to a sending error.

FOURTH: It is proven in the file, through a diligence dated July 1, 2024, that in the registry of the Spanish Agency for Data Protection, the following email address ***EMAIL.2 is listed as the DPD's contact information.

FIFTH: It is proven in the file, through a diligence dated July 1, 2024, that upon consulting the website of the entity being claimed against <https://cve.edu.es/politica-de-privacidad/>, the section corresponding to the privacy policy does not contain the contact details of the DPD.

SIXTH: It is established in the file, through the claimant's assertion and the provision of photographs, that the password for the email account created by the SCHOOL for all children was the initials of the minor plus the mother's date of birth, without forcing a change; which facilitated the impersonation of the minor's identity.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47,

48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Presidency of the Spanish Agency for Data Protection is competent to resolve this procedure. Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeaeprd.gob.es

6/27

II

Preliminary Issues

Article 4 of the GDPR, under the heading "Definitions," provides the following:

"1) 'personal data': any information relating to an identified or identifiable natural person ('the data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person;

Consequently, it is evident that a person's email address, according to Article 4.1 of the GDPR, is personal data and its protection is therefore subject to this Regulation.

In Article 4.2 of the GDPR, the concept of "processing" of personal data is defined.

2) 'processing': any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination, or any other form of making available, alignment or combination, restriction, erasure, or destruction."

In subsection seven of the same article of the GDPR, it is stated:

7) 'data controller' or 'controller': the natural or legal person, public authority, agency, or other body that, alone or jointly with others, determines the purposes and means of the processing; where the law of the Union or of the Member States determines the purposes and means of processing, the controller or the specific criteria for its designation may be provided by the law of the Union or of the Member States."

In this regard, it should be noted that the SCHOOL is the data controller of the personal data in the specific case at hand, the email address of the claimant's daughter, as it is the entity that determines the purposes and means of processing the personal data.

III

Allegations to the initiation agreement and the proposed resolution

In response to the allegations presented by the entity being claimed against, the following should be noted:

The entity states that.

1.

Regarding the first proven fact of the present

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeaeprd.gob.es

7/27

Sanctioning procedure regarding the creation of the email address, we must mention the following issues:

First of all, Article 6.1 of the General Data Protection Regulation (EU) 2016/679, in relation to the legal bases for the processing of personal data, includes among them, in its paragraph b), the necessary

processing of data for the execution of the provision of services (the processing is necessary for the execution of a contract in which the data subject is a party or for the application at their request of pre-contractual measures), and in its paragraph a), the consent of the data subject or, in the case of minors under 14 years of age, the consent granted by their guardian.

In this regard, we must mention that the situation of creating the email address responds to an educational need, and that, in the case presented, it was carried out during the exceptional period of COVID-19, due to the need for rapid adaptation of the existing educational systems at that time. The purpose of creating this account responds to the very execution and development of the training, and it was not possible, due to the lack of in-person attendance, for students to execute and attend through other means than those enabled at that exceptional moment.

As a result of the above, the communication regarding the creation of the email address was carried out via emails to the guardians of the minors, and there was no impediment or refusal from the guardian of the minor referred to in the complaint. In proof of the above, we provide emails (ANNEX I). Furthermore, after this moment of exceptional adaptation, we adapted our systems for obtaining authorization, in accordance with the requirements established by the legislator. In proof of the above, we provide the current document, which is provided to the guardians for the management of the classroom (ANNEX II).

In response to the allegations, this Agency must reiterate and emphasize that, under no circumstances and for the purposes of Article 6.1 of the GDPR, an emergency situation such as the global COVID-19 pandemic legitimizes, by itself, the processing of personal data without the consent of its holders or, where applicable, their guardians.

This agency is very surprised that the lack of consent from the data subject or, in the case of minors under 14 years of age, the consent granted by their guardian, has been replaced by a simple subsequent communication via email to the guardians of the minors, and it is even more surprising that full value is given to the consent itself simply because there was no impediment or refusal from said guardians.

In this regard, we must recall the provisions of Article 7 of the GDPR "Conditions for consent," which establishes that:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaepe@gob.es

8/27

"1. When the processing is based on the consent of the data subject, the controller must be able to demonstrate that the data subject has consented to the processing of their personal data.

The GDPR does not establish a specific mechanism regarding how the controller must be able to prove that valid consent has been obtained, allowing flexibility to implement the method of obtaining and recording that best suits the organization's processes. However, at a minimum, the controller must be able to verify who granted the consent, when, how, and for what purpose, as well as the information provided to the data subject at the time of obtaining consent. This obligation remains as long as the processing of personal data continues under the initial conditions in which the data was collected and must be verifiable in the event of an audit or inspection.

2. If the consent of the data subject is given in the context of a written statement that also refers to other matters, the request for consent must be presented in such a way that it is clearly distinguishable from other matters, in an intelligible and easily accessible manner, and using clear and simple language. No part of the statement that constitutes a violation of this Regulation shall be binding." The data subject must be provided with a minimum amount of information prior to giving consent, which is crucial for them to make a valid and clearly informed decision.

Furthermore, in this case, the provisions of the LOPDGDD regarding "Consent of minors" must be taken into account:

"1. The processing of personal data of a minor may only be based on their consent when they are over fourteen years of age.

Exceptions apply in cases where the law requires the presence of the holders of parental authority or

guardianship for the execution of the act or legal transaction in which consent for processing is obtained.

2. The processing of data of minors under fourteen years of age, based on consent, shall only be lawful if the consent of the holder of parental authority or guardianship is obtained, to the extent determined by the holders of parental authority or guardianship.”

The COLLEGE continues by stating:

2.

On the other hand, we consider it essential to mention the security measures and instructions conveyed in the management of this system that have been implemented, in compliance with the provisions of Articles 24 and 32 of the aforementioned European Data Protection Regulation:

SECURITY MEASURES:

The educational center must exercise due diligence to ensure that the data processor and, where applicable, sub-processors guarantee compliance with the required security measures.

In the Guide for Clients contracting Cloud Computing services published by the Agency to ensure compliance with security measures by the processor, various examples are provided:

- that the educational platform has a certification

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

9/27

of adequate security,

- that it is agreed that an independent third party audits the identified security measures, indicating the standards that will be applied,
- that the Center requests information on how the security measures will be audited,
- that the Center is informed about security incidents affecting personal data, as well as the measures taken to resolve them.

Collaboration procedures must be established between the data controller and the processors and sub-processors for the implementation and maintenance of security measures, as responsibility may, in many cases, be shared; therefore, the responsibilities of each party must be contractually defined.

The educational Center must take the necessary measures to ensure that all system users are aware of the Center's security policies.

The Personal Data Protection Regulation requires the preparation of a Security Document that outlines the technical and organizational measures that must be complied with by all personnel accessing personal data.

In cases where security measures must be of medium or high level, the educational Center must have a Security Officer who will be identified in the Security Document. The contracts signed must specify the frequency of backups, the person responsible for their execution, and the restoration of databases so that the educational Center is aware of the effective compliance with data protection regulations. When high-level security measures are required, the educational platform must ensure that the backup is located in a different place from the original database locations.

The educational Center must ensure the proper adequacy of access permissions to personal data according to each user's profile. To this end, the educational platform must collaborate to facilitate the appropriate assignment of profiles. The data controller must guarantee the confidentiality and integrity of passwords both in their assignment and in their distribution and storage. Password storage must be encrypted or use a procedure that allows passwords to be stored in an unintelligible manner. When passwords are distributed via email, a control mechanism must be established to ensure that the email recipient is the holder and requires a password change upon first access. Mechanisms must be implemented that require password changes at certain intervals, which in no case will exceed one year.

In processing environments with medium and high security levels, it is mandatory to establish a system that limits attempts at unauthorized access. It is considered good practice for the educational Center to raise awareness among its users about the dangers of using passwords that are not sufficiently robust.

Other aspects of the Security Measures considered by the School:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

10/27

The person responsible for the educational platform, acting as the data processor for the Centers, must establish mechanisms that ensure that only the data controller accesses their information, guaranteeing the independence of the data.

Educational platforms with high-level security measures must establish a secure channel for data transmission through encryption, or use a procedure that guarantees that the information is not intelligible.

When high-level security measures must be applied, it is mandatory to record accesses made to the data, including denied accesses, keeping the user's identification, the accessed record, the date and time, and storing it for at least two years. This information must be reviewed at least once a month by the Security Officer.

The use of mass access systems to data, such as web services, must be carried out under the same security policy as the other procedures included in the platform. In mobile apps, it would be advisable to request user identification and authentication for each access to the application, without storing the identification provided during the first access on the device. As an additional security measure, it would be good practice for accesses from apps to be associated with the devices, so that if a user identifies themselves on the platform through a different device than usual, they are asked for additional authentication.

In response to the allegations, this Agency has already stated that it welcomes the implementation of the security measures adopted given the estimated risks. However, the fact that the password for the email account created by the SCHOOL for all the children in the center was the initials of the minor plus the mother's date of birth, without forcing a change, evidences the weakness and lack of such reasonable security measures and, consequently, a breach of the obligations of the data controller regarding data protection.

The entity alleges that:

3.

Regarding the information provided in compliance with the duty of information, enshrined in Article 13 of the European Data Protection Regulation, we must point out the following issues:

First, it should be noted that the entity has adapted its systems for processing personal data in accordance with the provisions of the General Data Protection Regulation (EU) 2016/679 and Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights.

Likewise, the School does not allow the collection of data, as well as the processing of those data that are not strictly necessary for the purpose pursued in each case. That is to say, they must respond to a legitimate purpose, and cannot be collected fraudulently while complying with the duty of information regarding the data subjects. Furthermore, the data will be adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed. They will be accurate and must be kept up to date. Data that is not correct must be deleted or updated.

In the various documents provided to the guardians or minors of the center, information about data processing is provided. As proof of the above, we attach the enrollment form signed by the guardian of the minor (ANNEX III).

Additionally, the procedures for exercising rights in this area are in accordance with current regulations. As proof of the above, we provide the procedures implemented by the center and communicated through the different channels of the center (ANNEX IV).

Regarding compliance with these procedures and their effectiveness, in the specific case of the

guardian, the information and response were provided, as established by the legislator. As proof of the above, we attach the request received and the response provided (ANNEX V).

Moreover, the control authority has pointed out the lack of information regarding the contact related to the figure of the Data Protection Officer. In this regard, we must express our disagreement, as this figure is identified in our various procedures, data collection forms, clauses, and in the privacy policy on our website.

In response to the allegations, this body has already stated that the adaptation of the systems for processing personal data in accordance with the provisions of the General Data Protection Regulation (EU) 2016/679 and Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights is a legal obligation.

However, in light of the above, it is important to note what is prescribed in Article 13 "Information to be provided when personal data are obtained from the data subject," which establishes:

1. When personal data relating to a data subject are obtained from that data subject, the data controller shall provide all the information indicated below at the time the data is obtained:

- a) the identity and contact details of the controller and, where applicable, of their representative;
- b) the contact details of the data protection officer, where applicable;
- c) the purposes of the processing for which the personal data are intended and the legal basis for the processing;

12/27

d) when the processing is based on Article 6, paragraph 1, letter f), the legitimate interests of the controller or a third party;

e) the recipients or categories of recipients of the personal data, if applicable;

f) if applicable, the intention of the controller to transfer personal data to a third country or international organization and the existence or absence of an adequacy decision by the Commission, or, in the case of transfers referred to in Articles 46 or 47 or Article 49, paragraph 1, second sentence, reference to the appropriate or adequate safeguards and the means to obtain a copy of these or the place where they have been made available.

It is necessary to note and insist by this Agency that, as of the date of the initiation agreement and the proposal for resolution of this sanctioning procedure, the contact details of the data protection officer are still not included in the privacy policy of the COLEGIO <https://cve.edu.es/politica-de-privacidad>, continuing the commission of the infringement and the non-compliance with Article 13 of the GDPR, despite the measures taken, as stated in the diligence dated July 1, 2024.

4.

From the center, we consider it essential to convey other measures adopted due to the incident that arose at that time, which are:

In relation to the report regarding the measures taken to prevent similar incidents from occurring, implementation dates, and controls carried out, it is composed of the following measures:

From the management, we are aware that, in the data management processes, in which the staff of the Colegio is involved, training and awareness of the same is fundamental for an adequate processing of requests, inquiries, or incidents that may arise.

Likewise, in compliance with the principle of transparency, the Colegio periodically reviews any type of clauses, forms, or communications made, as established by Articles 13 and 14 of the European Data Protection Regulation.

Based on the above, the data controller has defined the following verifications as an integral part of the different existing processes:

- Review of the clauses in compliance with the duty of information, as well as the consent of the data subject or representative, for each of the purposes of data processing.
- Furthermore, from the center, fully aware that the management of these processes depends on the knowledge of the user in charge at the Colegio, a training program was developed during the year 2022 to achieve this culture of data protection.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

13/27

In this regard, in this initial organization, the training was aimed at the workers responsible for managing communications, with the objective of training and raising awareness among all, with the content of the training program being:

UNIT 1. THE EUROPEAN DATA PROTECTION REGULATION (EU) 2016/679

UNIT 2. FOUNDATIONS FOR DATA PROCESSING

UNIT 3. CONTROLLER AND PROCESSOR

UNIT 4. RIGHTS OF THE DATA SUBJECTS

UNIT 5. ACTIVE ACCOUNTABILITY MEASURES I

UNIT 6. ACTIVE ACCOUNTABILITY MEASURES II

As we anticipated earlier, the management processes regarding data protection are under constant review and assessment, as we are aware of the constant exposure and need to comply with the guarantees established by current regulations.

It is also worth noting that the Colegio, as the data controller, has adopted different measures in order to instill a culture and awareness regarding data protection.

First of all, it is important to highlight that the Colegio is adapted to the current regulations on data protection (Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, regarding the protection of natural persons and Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights), fulfilling the formal obligations established for this purpose by the legislator, which are as follows:

- Record of Processing Activities (minimum content of Article 30 of the GDPR).
- Regulation of relationships with third parties, through the signing of confidentiality contracts and access to data on behalf of third parties (Article 28 of the GDPR and Article 33 of Organic Law 3/2018, of December 5, on the protection of personal data and guarantee of digital rights).
- Confidentiality documents and duty of secrecy of the different users.
- Verification of the security measures implemented, in accordance with the provisions of Articles 24 and 32 of the GDPR.

As an integral part of the technical-organizational measures to ensure the security of information (confidentiality, integrity, and availability of data and the system in general), the necessary clauses and documents have been prepared for the workers and personnel dependent on the data controller to sign, and, in turn, to be trained regarding their obligations in data protection, the consequences in case of non-compliance with their obligations, and their duty of secrecy and confidentiality regarding the data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeprd.gob.es

14/27

data and information that they know due to their employment or commercial relationship with the Data Controller (RT), etc.; regarding this group, in their capacity as data subjects, the necessary clauses were developed to obtain their informed consent for the various processing activities that the RT carries out with their data. Finally, among these clauses, those that must train employees regarding the internal regulations of the RT in the so-called ICT Policies were included, which encompass the rules for the use of equipment, internet, corporate or private emails on the RT's equipment or resources, authorized accesses and operations, etc.

- Informative clauses developed for the various documents used for the usual activities of the entity.
- Procedure implemented for the exercise of rights by the data subjects.
- Procedure in the event of breaches or security incidents.
- Likewise, at that time, the appointment of the Data Protection Officer was carried out, as well as its communication to this supervisory authority, within the legally established timeframe for this purpose. Regarding the General Security Policy, approved by the College and which serves as the established

basis for the regulatory adaptation process in the Responsible entity:

1.- Rights of individuals in relation to personal data.

Data subjects can exercise their rights of access, opposition, rectification, cancellation or deletion (right to be forgotten), revocation of consent, limitation of processing, and data portability in accordance with current legislation, by sending a letter to our address, or contacting our DPO at: dpo@grupodata.es, or any other means, providing proof of their identity. Likewise, they have the right to file a complaint with the Spanish Data Protection Agency. I understand that this information, regarding the right to complain to the AEPD, is not mandatory in this case, as the document refers to the company's policy; it declares what pertains exclusively to the company.

2.- Collection of data and information. The collection of personal data will be carried out solely and exclusively for the purposes provided in activities directly related to the corporate object and purposes of the entity and using methods that have been approved by the Data Controller.

3.- Processing and consent.

Individuals from whom personal data is required will be informed of their rights and their consent will be obtained by the established methods and in the terms required by applicable legislation.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sede.aepd.gob.es

15/27

4.- Transfers, Confidentiality, and Duty of Secrecy.

All communications regarding personal data between the College and the interested parties, and any other entity or person involved in the processing, will be considered confidential.

All parties involved in the processing will provide evidence of their commitment to confidentiality.

5.- Transfer of personal information to third parties.

The College does not sell, assign, lease, or transmit, in any way, personal information or data of its Clients/Users to third parties, except for transfers covered by law and to authorized Data Processors. Changes affecting the processing of personal data will also be communicated to the interested parties by the most appropriate means in each case.

6.- Responsibility, cooperation, and participation.

The College, as the Data Controller, requests the commitment and active participation of all staff for the correct application, updating, and improvement of this Data Protection Policy.

In response to the allegations, this Agency has already indicated that the adoption of all these measures as a consequence of the incident that arose at that time denotes a lack of appropriate technical and organizational measures to ensure a level of security adequate to the risk of processing. Article 32 of the GDPR does not establish a list of security measures applicable according to the data being processed, but rather establishes that the controller and the processor shall apply technical and organizational measures that are appropriate to the risk involved in the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the risks of likelihood and severity for the rights and freedoms of the data subjects. Furthermore, the security measures must be adequate and proportionate to the detected risk, indicating that the determination of technical and organizational measures must be made taking into account, among others: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, verification process (not an audit), evaluation, and assessment of the effectiveness of the measures.

It is evident that the security measures implemented were insufficient.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sede.aepd.gob.es

16/27

Regardless of the measures adopted to prevent similar incidents from occurring, as well as other measures taken, what is decisive is that there were not sufficient measures in place or they had not been properly implemented at the time the incident occurred.

Although this Agency values the effort made by the SCHOOL to fulfill its obligation, as the data controller, to apply appropriate technical and organizational measures to ensure a level of security adequate to the risk in the processing of personal data.

Evidently, training and awareness regarding data protection for the personnel providing services at the SCHOOL falls within the obligation of the data controller to apply appropriate technical and organizational measures to ensure a level of security adequate to the risk.

Such organizational measures of a human factor are essential and extremely important to avoid, prevent, react to, and mitigate the effects of incidents like the one that occurred.

Finally, and in reference to the above, it is necessary to note the ruling of the AN dated February 9, 2023 (rec. 770/2022) which states:

“(…) The security measures implemented subsequently do not affect the commission of the infringement and, contrary to what the plaintiff intended, cannot justify the application of an exemption, without prejudice to them being considered as a mitigating factor under Article 83.2.c) of the GDPR when determining the sanction.”

Consequently, and as this is a reiteration of the statements already made, the allegations are once again DISMISSED.

IV

Unfulfilled obligation. Lawfulness of processing

Article 6 of the GDPR establishes, regarding the lawfulness of the processing of personal data obtained from users, that the processing of such data will only be lawful if at least one of the conditions indicated in its first paragraph is met, among which is, in its paragraph a): “that the data subject has given consent to the processing of their personal data for one or more specific purposes (…)”.

Regarding the processing of data based on the consent of the data subject, Article 7 of the GDPR indicates that the data controller must be able to demonstrate that the data subject consented to the processing of their personal data. If consent is given in the context of a written declaration that also refers to other matters, it must be ensured that the request for consent is clearly distinguishable from other matters and presented in an intelligible manner, easily accessible, and using clear and simple language. Additionally, it is required that the data subject is provided with additional information, among other things, regarding what the categories of data will be.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sede@aepd.gob.es

17/27

to address, the purposes for which consent is requested and the right to withdraw consent at any time.

Regarding the manner of obtaining the consent of the data subject for the processing in question, Recital 32 of the GDPR states that it “must be given by a clear affirmative act that reflects the data subject's free, specific, informed, and unambiguous indication of their wishes to accept the processing of personal data concerning them” and that “silence, pre-ticked boxes, or inactivity should not constitute consent.” It is also required that consent be granted “for all processing activities carried out for the same or similar purposes. When processing has multiple purposes, consent must be given for all of them.” Finally, it establishes that “if the data subject's consent is to be given following a request by electronic means, the request must be clear, concise, and not unduly disrupt the use of the service for which it is provided.”

For its part, Article 7 of the LOPDGDD dedicated to “Consent of Minors” establishes that,

1. The processing of personal data of a minor may only be based on their consent when they are over fourteen years old. Exceptions are made in cases where the law requires the assistance of the holders of parental authority or guardianship for the execution of the act or legal transaction in which consent for processing is obtained.

2. The processing of data of minors under fourteen years old, based on consent, will only be lawful if the consent of the holder of parental authority or guardianship is obtained, to the extent determined by the holders of parental authority or guardianship.

In this case, the claimant states that the SCHOOL created an email account for their daughter, a minor under 14 years old, without having obtained the consent of the guardians for the creation of said email account.

Since the claimant's daughter is under 14 years old, regarding the creation of said email account, the consent or authorization of the holders of parental authority or guardianship of the minor should be obtained for the creation of the email account ***EMAIL.1, and the data controller must be able to demonstrate that the holders of parental authority or guardianship of the minor consented to the processing of the minor's personal data, in accordance with the provisions of Article 7 of the GDPR, a circumstance that is not present in the file.

Consequently, the events that occurred are considered to constitute an infringement, attributable to the SCHOOL, for violation of Article 6.1 of the GDPR.

V

Classification and qualification of the infringement of Article 6.1 of the GDPR.

The aforementioned infringement of Article 7.2 of the GDPR constitutes the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeae@epd.gob.es

18/27

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 72 "Infringements considered very serious" of the LOPDGDD indicates:

"1. Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following are considered very serious and shall prescribe after three years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

b) The processing of personal data without any of the conditions for lawful processing established in Article 6 of Regulation (EU) 2016/679. (...)"

VI

Sanction for the infringement of Article 6.1 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, it is appropriate to gradate the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

As a circumstance to be taken into account in determining the sanction:

- b) the intent or negligence in the infringement;

In this same sense, the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be emphasized that rigor and

exquisite care must be taken to comply with the legal provisions in this regard.

[Judgment of the National Court of 17/10/2007 (rec. 63/2006)].

It is also considered appropriate to gradate the sanction to be imposed according to the following criteria established in paragraph 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As a circumstance to be taken into account in determining the sanction:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

19/27

-

b) The connection of the infringer's activity with the processing of personal data.

The SCHOOL, in the exercise of its educational activity and in the specific processing of personal data subject to this sanctioning procedure, routinely processes personal data of both the teachers and the students of the center. In this regard, it should be noted that the email address is based on the initial and the first surname of the complainant's daughter and that the established password was the mother's date of birth. All of these are, therefore, personal data subject to processing by the respondent.

-

f) The impact on the rights of minors.

The creation of an email account, as well as the use of various educational applications, without having obtained the consent of their parents or guardians, affects a minor student of the SCHOOL. The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 6.1 of the GDPR, allows for the imposition of a fine of €4,500 (FOUR THOUSAND FIVE HUNDRED EUROS).

VII

Article 13 GDPR

Article 13 "Information to be provided when personal data are obtained from the data subject" states that:

1. When personal data relating to a data subject are obtained from that data subject, the data controller shall provide the data subject with all the information indicated below at the time of obtaining the data:

a) the identity and contact details of the controller and, where applicable, of its representative;

b) the contact details of the data protection officer, where applicable;

c) the purposes of the processing for which the personal data are intended and the legal basis for the processing;

d) where the processing is based on Article 6(1)(f), the legitimate interests pursued by the controller or a third party;

e) the recipients or categories of recipients of the personal data, if any;

f) where applicable, the intention of the controller to transfer personal data to a third country or international organization and the existence or absence of an adequacy decision by the Commission, or, in the case of transfers referred to in Articles 46 or 47 or Article 49(1), second paragraph, reference to the appropriate or suitable safeguards and the means to obtain a copy of them or the place where they have been made available.

A privacy policy is a written presentation of all the measures that a company or organization applies to ensure the security and lawful use of the personal data of users or clients that it collects and processes in the context of any relationship, whether commercial or service-related.

The content of the privacy policy must comply with the information that must be provided when the data are obtained from the data subject.

In this case, the privacy policy of the SCHOOL <https://cve.edu.es/politica-de-privacidad> did not include the contact details of the data protection officer, as was already pointed out in the initiation agreement of this procedure. This Agency has confirmed that these details are still not included as of the date of this resolution.

Consequently, the known facts constitute an infringement attributable to the SCHOOL for violating

Article 13 of the GDPR.

VIII

Classification and qualification of the infringement of Article 13 of the GDPR.

The aforementioned infringement of Article 13 of the GDPR constitutes the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides:

"Violations of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to up to 4% of the total annual global turnover of the preceding financial year, opting for the higher amount:

b) the rights of data subjects under Articles 12 to 22; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that "Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the limitation period, Article 74 "Minor infringements" of the LOPDGDD indicates:

"1. The remaining formal infringements of the articles mentioned in paragraphs 4 and 5 of Article 83 of Regulation (EU) 2016/679 shall be considered minor and shall be subject to a one-year limitation period, in particular, the following:

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeepd.gob.es

21/27

a) The failure to comply with the principle of transparency of information or the right of the affected party to information by not providing all the information required by Articles 13 and 14 of Regulation (EU) 2016/679. (...)"

IX

Sanction for the infringement of Article 13 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, it is necessary to graduate the sanction to be imposed in accordance with the following criteria established by Article 83.2 of the GDPR:

As a circumstance to be taken into account in determining the sanction:

-

b) the intentionality or negligence in the infringement;

In this same sense, the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. In assessing the degree of diligence, special consideration must be given to the professionalism or lack thereof of the subject, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be emphasized that there is a need for rigor and exquisite care to comply with the legal provisions in this regard.

[Judgment of the National Court of 17/10/2007 (rec. 63/2006)].

It is also considered appropriate to graduate the sanction to be imposed in accordance with the following criteria established in paragraph 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As a circumstance to be taken into account in determining the sanction:

-

b) The connection of the infringer's activity with the processing of personal data.

The COLLEGE, in the exercise of its educational activity, routinely processes personal data of both the teachers and the students of the center. This fact makes it particularly relevant that there is adequate and transparent information that allows for the proper exercise of the rights held by the data subjects and, specifically, by their data protection officer.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, with respect to the infringement committed by violating the provisions of Article 13 of the

GDPR, allows for the imposition of a sanction of €1,000 (ONE THOUSAND EUROS).

X

Article 32 of the GDPR

Article 32 “Security of processing” of the GDPR establishes:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sede.aepd.gob.es

22/27

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law.”

Thus, this provision requires the adoption of security measures, which may be of a technical or organizational nature, and which must be appropriate to the risk of the processing of personal data carried out. Conversely, this provision would be violated if such measures were not adopted, which, appropriate to the risk and in general, would guarantee the security of the processing.

The obligation to adopt all technical and organizational measures imposed by Article 32 of the GDPR on the data controller is a manifestation of the two essential pillars of the GDPR: proactive responsibility enshrined in Article 5.2 and developed in Article 24.1 of the GDPR and the risk-based approach. Thus, Article 32, while establishing a set of measures that could be considered minimal to be adopted by the controller, cannot in any case be understood as a *numerus clausus* since these must address the nature, scope, context, and purposes of the processing, as well as the risks of probability and severity affecting personal data.

As can be seen, there has been an evolution from a reactive system to a proactive one, based on prevention and not on responding to a specific incident that warranted it.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sede.aepd.gob.es

23/27

must be corrected, and it must operate throughout the entire lifecycle of personal data.

In this regard, Recital 74 of the GDPR states (the emphasis is from the AEPD):

“74 The responsibility of the data controller for any processing of personal data carried out by

themselves or on their behalf must be established. In particular, the controller must be obliged to implement appropriate and effective measures and must be able to demonstrate compliance of the processing activities with this Regulation, including the effectiveness of the measures. Such measures must take into account the nature, scope, context, and purposes of the processing, as well as the risk to the rights and freedoms of natural persons.”

For its part, the Supreme Court ruling of February 15, 2022 (Rec. 7359/2020) indicates that “It is not enough to design the necessary technical and organizational means; their correct implementation and appropriate use are also necessary, so that they will also be liable for the lack of diligence in their use, understood as reasonable diligence considering the circumstances of the case.”

Furthermore, the CJEU in its ruling of December 14, 2023, in case C-340/21 has stated regarding “whether the principle of responsibility of the data controller, as set out in Article 5, paragraph 2, of the GDPR and developed in Article 24 of the same, should be interpreted to mean that... the data controller bears the burden of proof of the appropriateness of the security measures it has adopted in accordance with Article 32 of the aforementioned Regulation,” concluding that “From the wording of Articles 5, paragraph 2, 24, paragraph 1, and 32, paragraph 1, of the GDPR, it is unequivocally clear that the burden of proof that personal data is processed in a manner that ensures adequate security, in the sense of Articles 5, paragraph 1, letter f), and 32 of that Regulation, rests with the data controller in question [see, by analogy, the judgments of May 4, 2023, Bundesrepublik Deutschland (Judicial electronic mailbox), C-60/22, EU: C:2023:373, paragraphs 52 and 53, and of July 4, 2023, Meta Platforms and others (General terms of service of a social network), C-252/21, EU:C:2023:537, paragraph 95].” (paragraph 52)

This CJEU ruling also indicates the following:

“[the adoption of security measures regarding the protection of personal data] is not fulfilled by the adoption of any measure, as they must be necessary to guarantee those objectives set by the provision, and of course, it is not enough to have formal approval of the security measures, as it is required that they be established and effectively implemented. We have consequently considered that a result obligation is imposed, consisting of adopting the necessary measures to prevent data from being lost, misplaced, or ending up in the hands of third parties. Ultimately, every data controller (or processor) is, by legal provision, a debtor of security regarding data, and must ensure that such measures or mechanisms are effectively implemented in practice.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaepd.gob.es

24/27

In summary, we are faced with an obligation of the data controller consisting of the adoption of technical and organizational security measures, and it is the responsibility of said controller to demonstrate their implementation and adequacy in light of the risk arising from the processing. Considering the above, in the present case, at the time the events occurred, it is noted that the SCHOOL did not have reasonable security measures in place based on the estimated potential risks, especially given that it involved a communication channel between the SCHOOL and its students, who are minors.

The fact that the email password for all the children at the school was the initials of the minor plus the mother’s date of birth, without enforcing a change, evidences the lack of such reasonable security measures.

Consequently, the known facts constitute an infringement attributable to the SCHOOL for violation of Article 32 of the GDPR.

XI

Classification of the infringement of Article 32 of the GDPR

The aforementioned infringement of Article 32 of the GDPR constitutes the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” states:

“Violations of the following provisions shall be subject to administrative fines of up to EUR 10,000,000 or, in the case of an enterprise, an amount equivalent to up to 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)” In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the limitation period, Article 73 “Infringements considered serious” of the LOPDGDD indicates:

“Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall prescribe after two years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

(...)

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing, in the terms required by Article 32.1 of Regulation (EU) 2016/679.

XII

Sanction for the infringement of Article 32 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, it is considered that the infringement in question is serious for the purposes of the GDPR and that it is appropriate to graduate the sanction to be imposed in accordance with the following criteria established in Article 83.2 of the GDPR:

As a circumstance to be taken into account in setting the sanction:

- b) the intentionality or negligence in the infringement;

In this same sense, the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, special consideration must be given to the professionalism or lack thereof of the subject, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be emphasized that rigor and exquisite care must be taken to comply with the legal provisions in this regard.

[Judgment of the National Court of 17/10/2007 (rec. 63/2006)].

It is also considered appropriate to graduate the sanction to be imposed in accordance with the following criteria established in paragraph 2 of Article 76 “Sanctions and corrective measures” of the LOPDGDD:

As a circumstance to be taken into account in setting the sanction:

- b) The link between the infringer's activity and the processing of personal data.

The SCHOOL, in exercising its educational activity and in the specific processing of personal data subject to this sanctioning procedure, regularly processes personal data of both teachers and students of the center. In this regard, it should be noted that the email address is based on the initial and the first surname of the complainant's daughter, and the established password was the mother's date of birth. All of these are, therefore, personal data subject to processing by the respondent.

- f) The impact on the rights of minors.

The creation of an email account, as well as the use of various educational applications, for which the necessary security measures were not in place, affects a minor student of the SCHOOL.

The balance of the circumstances considered in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, with respect to the infringement committed by violating the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeapd.gob.es

26/27

Established in Article 32 of the GDPR, allows for the imposition of a fine of €4,500 (FOUR THOUSAND

FIVE HUNDRED EUROS).

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of sanctions whose existence has been established,

the Presidency of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on COLEGIO VIRGEN DE EUROPA, S.L., with NIF B28773794, for an infringement of Article 6.1 of the GDPR and Article 13 of the GDPR classified under Article 83.5 of the GDPR, and for an infringement of Article 32 of the GDPR classified under Article 83.4 of the GDPR, the following fines:

- For the infringement of Article 6.1 of the GDPR, classified under Article 83.5 of said regulation, an administrative fine of €4,500.00.
- For the infringement of Article 13 of the GDPR, classified under Article 83.5 of said regulation, an administrative fine of €1,000.00.
- For the infringement of Article 32 of the GDPR, classified under Article 83.4 of said regulation, an administrative fine of €4,500.00.

SECOND: NOTIFY this resolution to COLEGIO VIRGEN DE EUROPA, S.L.

THIRD: This resolution shall be enforceable once the period for filing the optional appeal for reconsideration (one month from the day following the notification of this resolution) has expired without the interested party having exercised this right.

The sanctioned party is warned that they must pay the imposed sanction once this resolution becomes enforceable, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account No.

IBAN: ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once enforceable, if the date of enforceability falls between the 1st and the 15th of each month, inclusive, the period for voluntary payment will be until the 20th of the following month or the next business day, and if it falls between the 16th and the last day of each month, inclusive, the payment period will be until the 5th of the second following month or the next business day.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sede@aepd.gob.es

27/27

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may file, optionally, an appeal for reconsideration before the Presidency of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish

Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeaepd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not become aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, the provisional suspension will be considered terminated.

938-100325

Lorenzo Cotino Hueso

President of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaepd.gob.es